

Decision Rationale

Corgi Cyber Protection Policy (CORG-CY-0200) · Sample insured: Cedar Ridge Accounting Group, LLC · September 2026

1. Summary

I wrote this policy for small and mid-sized businesses like Cedar Ridge Accounting Group, the fictional sample insured: a 62-person Denver accounting firm holding Social Security numbers and tax records for about 31,000 people. Its only cyber cover today is \$50,000 inside its business policy, and two clients now require \$1 million.

A client requirement is why a firm like this buys. But the losses most likely to hurt it are its own: a ransomware outage, a diverted payment, its cloud tax platform going down. So I made three calls.

- 1. **Ransomware, lost income, data restoration and payment fraud are core cover.** Corgi's startup form sells them as add-ons. [7] That works for buyers who know what to pick; a first-time buyer may not. The cost is more exposure for the insurer.
- 2. **Provider outages and accidents get lower caps.** One vendor failure can hit many insured firms at once, so these risks are capped separately while the core stays at full limits.
- 3. **A failed security control or an honest application error does not, by itself, cost the firm its cover.** That shifts risk to the insurer, and I have not priced it.

All premiums, limits and loss figures are my assumptions, not quotes or actuarial results.

2. The key decisions

Each row gives the decision, the reason and what it costs. Two terms: the **deductible** (the policy calls it the retention) is what the firm pays first, and lost-income cover uses a **waiting period** instead of a deductible, so the first hours of an outage are not paid.

Decision	What I chose	Why	What it costs
Total cover per year	\$2,000,000, including defense costs	Two clients already require \$1 million. At-Bay's 2025 ransomware claims with an outage payment averaged about \$510,000, against \$168,000 without one, in a book that includes larger firms. [5, pp. 26, 43] In an illustrative severe year of \$1.3 million, \$1 million leaves the firm \$300,000 short; \$2 million pays \$1.29 million and leaves \$710,000 for the rest of the year.	A higher premium than \$1 million; losses above \$2 million stay with the firm.
Deductible	\$10,000, once per incident	A firm this size can absorb small bills. One deductible applies even when an attack triggers several coverages.	Small losses stay with the firm.
Fast fraud reporting	Deductible falls to \$2,500 if payment fraud is reported within 72 hours	Fast reporting improves the chance of getting stolen money back. [5, p. 34] The discount pays owners to call quickly.	The insurer absorbs up to \$7,500 more.

Decision	What I chose	Why	What it costs
Free first help	Incident response: first 7 days, up to \$25,000 each incident and \$75,000 a year, outside the \$2 million and with no deductible	Early expert help limits the damage, and a free call gets owners calling sooner.	The insurer pays early costs; the caps bound them.
Waiting periods	8 hours for most outages; 24 hours for accidental provider outages	8 hours pays for real outages quickly. Chubb pays extra costs from the first hour [10, p. 17]; I applied one wait to both lost income and extra costs to keep claims simple. Accidental provider outages are the likeliest to hit many firms at once, so the firm keeps a full day.	Losses during the wait.
Accidents in the firm's own systems	\$250,000 shared cap for lost income and restoration	One faulty update can take down many insureds at once, so accidents get a cap sized to an ordinary outage. It pays my base case (\$155,000) but not my tax-season stress case (\$298,750); see the Appendix.	\$48,750 in the stress case.
Outages at a cloud provider	\$500,000 if the provider is hacked; \$250,000 if it fails by accident (bought)	Cedar Ridge has no full substitute for its cloud tax and payroll platforms. Provider limits sit below the \$2 million because one provider failure hits many insureds.	Provider losses above these caps.
Payment fraud	\$250,000 (options: \$500,000 or \$1 million)	Cedar Ridge holds no client money, and its 60 or so monthly supplier payments are usually under \$25,000, so its likely loss is one or a few diverted payments. Invoice diversion pays the firm's net cost, not the invoice total.	A single transfer above \$250,000.
Longest paid outage	180 days	Recovery can take months. Ninety days would stop too early; a year adds exposure without much benefit.	Losses after 180 days.
Refusing a settlement	Firm pays 30% of damages above the refused offer and of later defense costs	Discourages costly refusals while the insurer still pays most of the cost. At-Bay uses 20%. [1, p. 6] Example: refuse \$5,000; costs reach \$30,000; after the \$10,000 deductible the insurer pays 70% (\$14,000) and the firm \$16,000.	A 30% share after refusing.
Extra time for late claims	60 days free after the policy ends; 12 months for 75% or 24 months for 125% of premium	Claims can arrive after a policy ends. The free period bridges a short gap; the paid options suit a firm closing or switching insurers (\$6,000 or \$10,000 at the sample premium).	The price factors need testing against claims data.
Premium	\$8,000 illustrative: \$7,500 core + \$500 for accidental provider outages	Round figures to complete the Declarations.	—

3. What I included and what I left out

Core cover, in every policy

- **Breach response**, including help for people facing tax-related identity theft. With tax records for about 31,000 people, this is the breach cost Cedar Ridge's clients are most likely to need.

- **Ransomware and extortion.** The firm never has to pay a ransom to keep its cover. Any payment needs our written consent, a sanctions check under Treasury's OFAC advisory [11], and a report to the FBI or CISA unless law enforcement advises otherwise.
- **Lost income, data restoration and security upgrades.** Upgrades are paid only when our response team recommends them in writing, so a claim never becomes a general IT refresh.
- **Payment and invoice fraud, and liability:** privacy lawsuits, regulators, card-brand fines and media claims.
- **Why regulatory cover is core for a firm like this.** As a tax preparer, Cedar Ridge falls under the FTC Safeguards Rule, which since May 2024 requires notifying the FTC within 30 days of a breach affecting 500 or more people. [12] Colorado requires notice to affected residents within 30 days. [13] IRS Publication 4557 tells tax professionals to keep a written security plan. [14] So regulatory defense and penalties are core cover, legally required notices never need our consent, and the application asks for the written plan.
- **Small capped extras:** replacing computers bricked by an attack, lost profit after bad press, and hackers running up cloud or phone bills.

Optional

- **Accidental provider outage: bought.** Cedar Ridge cannot work without its cloud platforms; offline work is only a temporary workaround.
- **Website-tracking lawsuits: not bought.** Cedar Ridge runs Google Analytics 4 behind a consent banner, with no ad pixels, session replay or chat widget. The remaining risk is small, so the firm keeps it.

Left out on purpose

- **Professional mistakes.** A tax-preparation error belongs on the firm's \$2 million errors-and-omissions policy. A breach that happens during professional work stays covered, and this policy defends it without waiting for the other insurer.
- **Deliberate theft by insiders.** If a current owner, employee or individual contractor wires money out or diverts a customer's invoice payment, fraud cover pays nothing. That keeps it cyber-fraud cover, not employee-dishonesty cover. Cedar Ridge has no crime policy, so this is a real gap, and the application flags it.
- **Tracking suits** (covered only by the tracking option) **and biometric-privacy suits.** Statutory damages can far exceed a small-business premium. A hack that exposes biometric data is still covered.
- **Utility, internet backbone and natural-disaster outages.** These cannot be priced into a small-business premium. Security failures in the firm's systems, and failures inside a provider's own systems, stay covered.
- **War and major state-backed attacks.** The wording follows the structure of the Lloyd's Market Association model clauses. [15] Ordinary ransomware and fraud by state-linked groups stay covered. For major state-backed attacks, systems outside the country hit stay covered. The insurer must prove the exclusion applies, and response and defense continue until it does.

4. How I structured the definitions

The policy has 60 numbered definitions. Each covers one idea and carries its own exceptions, so a reader does not have to hunt for a distant exclusion. These choices do most of the work:

- **Two timing rules.** The firm's own losses count if first discovered during the policy year. Lawsuits count if first made during the policy year and reported within 90 days after it ends. Lawsuits can arrive years after a breach, so they need a fixed date to tie them to one policy.
- **One umbrella term, "incident".** It covers attacks, accidents, privacy breaches, extortion, fraud and bad press, and related events count as one. So one trigger and one deductible work across all of the firm's own losses: a ransomware attack costs one \$10,000 deductible, not three.
- **The firm's systems versus its provider's.** The firm's cloud accounts, settings and data count as its own systems; the provider's servers do not. A hacked Microsoft 365 account is Cedar Ridge's own security failure, covered up to the full \$2 million. A Microsoft outage is a provider event with its own cap. At-Bay and Travelers draw the same line. [1, p. 3; 2, pp. 2, 4, 7, 11]
- **Stolen passwords count as a hack.** Many small-firm intrusions start with a stolen or phished password. Naming it removes the argument that the login was "authorized".
- **Fraud means outsiders.** Payment fraud covers deception by outsiders, including deepfake audio and video, and excludes insiders by role.
- **Accidents are defined separately from attacks.** Human error, a faulty vendor update or a malfunctioning AI tool is a "system failure", with its own cap.
- **AI agents.** The policy defines when an AI tool "exceeds its authority", and states that using AI never, by itself, excludes a loss. AI tools already sit in email and payment workflows.

5. How it works in a real claim

- **One call counts as notice.** DUAL treats its hotline as help only and requires separate formal notice. [3, pp. 3, 15] I made the call count, which means the insurer must record and route every call.
- **No permission needed to act fast.** The firm can use approved vendors, make legally required notices, contain an attack in the first 72 hours, or settle within its deductible without asking first. We pay vendors directly where we can.
- **Shutting down to contain an attack is covered,** even when a government agency orders the shutdown. An owner who pulls the plug on good advice should not lose cover for it.
- **Security answers are not warranties.** A missed callback or a failed backup does not, by itself, reduce a covered payment. I removed security credits and penalties; Coalition's managed-detection credit is a possible later model. [9] The trade-off is more risk for the insurer, so the application checks controls before issue, using questions shaped by NIST's small-business guide. [6]
- **Honest application mistakes** do not void the policy. Only the premium and deductible can change, from the date we give notice. Voiding the policy is reserved for an executive's knowing, material misstatement.
- **No cut-off date for earlier events.** Cedar Ridge has operated since 2009 and is replacing existing cover, so a cut-off would open a gap. Problems it knew about but did not disclose stay excluded.
- **Service targets.** We aim to call back within one hour and decide coverage within 30 days of receiving the documents we ask for. Agreed amounts are paid within 15 days, with 8% annual interest when late. Once lost-income cover is confirmed, we advance 50% of the estimated loss within 10 business days.

6. Underwriting view of Cedar Ridge

The application shows a well-run firm with four gaps. I would offer the policy with these conditions and notes.

- **Conditions to bind.** Replace the Windows Server 2012 R2 print server, which no longer gets security updates, by December 2026 as the application plans. Put MFA on the internal scanner account that lacks it, or restrict what it can reach.
- **Referral note: no 24/7 monitoring.** Front Range IT Partners reviews alerts on business days, 8 a.m. to 6 p.m. An attack that starts on a Friday night can run until Monday. I would price for that, or offer a credit for 24/7 managed detection later. [9]
- **Advice to the client: insider theft.** Cedar Ridge has no crime policy, and this policy does not cover theft by its own staff. I would recommend a separate crime policy.
- **Disclosed problems.** Anything disclosed in the application is not a "known problem" under exclusion 2, so it stays covered unless an endorsement excludes it. That puts the burden on the underwriter to read every disclosure before binding. Here, none describes a live compromise.
- **Evidence the controls work.** In February 2025 a callback stopped a payment to false bank details, and in March 2026 MFA blocked a phished password. Both support the \$250,000 fraud limit and the standard deductible.

7. Three claim tests

Each test assumes unused limits, timely reporting and no other insurance or recoveries. Lost-income amounts are after the waiting period.

Event	Result
Ransomware: \$20,000 incident response + \$100,000 breach costs + \$150,000 restoration + \$200,000 lost income = \$470,000	One \$10,000 deductible; the insurer pays \$460,000. The \$20,000 of incident response sits outside the \$2 million, so \$440,000 uses it and \$1.56 million remains . The firm pays \$10,000 plus losses during the 8-hour wait.
Accidental outage of the firm's own systems: \$200,000 lost income + \$100,000 restoration = \$300,000	The deductible applies to restoration only, so \$290,000 qualifies. The shared accident cap pays \$250,000 ; the firm bears \$50,000 plus losses during the wait; \$1.75 million remains . The accident cap is used up for the year.
A payroll clerk deliberately steals \$100,000	Fraud cover pays \$0 : theft by an employee is neither payment fraud nor computer fraud. The firm bears \$100,000 and the full \$2 million remains.

8. How I used outside sources

- **Existing policies, to learn the standard shape.** I read complete small-business forms from At-Bay, Travelers, DUAL, Coalition and Chubb, following each coverage through its definitions, exclusions and conditions. [1–4, 10] Where they differed, I picked one, and the tables above name the form and the reason. Coalition's specimen showed that an endorsement can quietly change a base rule, so I read those too. [4]
- **Claims data, to see where losses are heading.** At-Bay's 2026 report showed that ransomware with downtime costs about three times as much as ransomware without it, and that fraud reported fast is more

often recovered. [5, pp. 26, 34, 43] That is why attacks get full limits and fraud gets the 72-hour discount. I also named newer risks the older forms say little about: deepfake fraud, AI tools acting outside their permissions, and invoice diversion after a hack.

- **Frameworks, law and guidance, to keep it workable.** NIST's small-business guide shaped the application's security questions. [6] Treasury's OFAC advisory set the ransom-payment rules. [11] The FTC Safeguards Rule, Colorado's notice law and IRS Publication 4557 explain why regulatory cover is core for a tax preparer. [12–14] The Lloyd's model clauses shaped the war exclusion. [15] Travelers' fraud supplement helped with the payment questions. [8]

Appendix: the income model behind the \$250,000 accident cap

The application gives \$8.1 million prior revenue and \$8.5 million projected revenue. The breakdown below is my assumption.

Annual input	Assumed amount
Pretax profit	\$1,275,000
Payroll that continues during an outage	\$4,800,000
Other continuing costs	\$1,400,000
Costs avoided during an outage	\$1,025,000
Total (matches projected revenue)	\$8,500,000

- **Daily basis.** Profit plus continuing costs is \$7,475,000. Over 260 earning days, that is **\$28,750 a day**.
- **Base case.** Four lost days plus \$40,000 of extra costs: $(\$28,750 \times 4) + \$40,000 = \textbf{\$155,000}$. This fits within the \$250,000 cap if no restoration claim competes for it.
- **Stress case.** Six days in tax season at 1.5 times the daily basis, plus \$40,000: $(\$28,750 \times 1.5 \times 6) + \$40,000 = \textbf{\$298,750}$. The cap leaves **\$48,750** with the firm. The 1.5 factor tests sensitivity; it is not a forecast.

I kept the \$250,000 cap knowing the stress case exceeds it. Seasonal accounts, recoverable work and available cash could change that choice.

References

Page numbers are PDF viewer pages. These are the editions I compared, not a claim that each is the insurer's current product.

1. **At-Bay, Cyber Insurance Policy** (AB-CYB-001.2, 08/2023 specimen). Used for: own vs. provider interruption (p. 3); the settlement split (p. 6).
2. **Travelers, CyberRisk Coverage** (CYB-16001, 06/2020 sample). Used for: how coverage, systems and providers are separated (pp. 2, 4, 7, 11).
3. **DUAL, Cyber and Data Protection Policy** (North America, "Cyber Wording 2026"). Used for: hotline help vs. formal notice (pp. 3, 15).
4. **Coalition, Oregon specimen policy package** (CYUSP-00PF-1022-01 with endorsements). Used for: how an endorsement can replace base reporting rules (p. 64).

5. **At-Bay, InsurSec Report 2026** (April 2026). Used for: 2025 ransomware costs (pp. 26, 43); fraud reporting and recovery (p. 34).
6. **NIST, CSF 2.0 Small Business Quick-Start Guide** (SP 1300, February 2024). Used for: the application's security questions (pp. 3–8).
7. **Corgi, Cyber Liability Insurance for Startups** (summary of CORG-CY-0100, reviewed April 24, 2026). Used for: comparing how own-loss cover is packaged.
8. **Travelers, Social Engineering Fraud Supplement** (CYB-14301, 01/2019). Used for: payment-control questions (pp. 1–2).
9. **Coalition, Managed Detection and Response, US** (updated August 1, 2024). Used for: security credits as a possible later model.
10. **Chubb, Cyber Enterprise Risk Management** (PF-48169, 02/2019 small-business sample). Used for: waiting period and extra costs (p. 17).
11. **U.S. Treasury / OFAC, Updated Ransomware Advisory** (September 21, 2021). Used for: sanctions checks and reporting before any ransom payment (pp. 1, 3–6).
12. **FTC, Standards for Safeguarding Customer Information (Safeguards Rule)**, 16 C.F.R. Part 314, breach-notification amendment effective May 13, 2024. Used for: why regulatory cover is core for a tax preparer.
13. **Colorado Revised Statutes § 6-1-716** (notification of security breach). Used for: the 30-day notice to Colorado residents.
14. **IRS Publication 4557, Safeguarding Taxpayer Data**. Used for: the written security plan the application asks about.
15. **Lloyd's Market Association, state-backed cyber-attack exclusion model clauses** (LMA5564–LMA5567, November 2021). Used for: the structure of the war exclusion.

Prepared by Rana for the Corgi take-home.